Assignment 1

Himanshu Kumar

TASK A | SECURE A STUDENT ACCOUNT (25 MARKS)

A1 & A2. Risk Identification, CIA Impact, Controls & Limitations Matrix

The following analysis evaluates the operational security scenario of Mira's academic accounts, detailing vulnerabilities across the Confidentiality, Integrity, and Availability (CIA) triad alongside mitigations and inherent limitations.

Identified Risk	Asset at Risk	CIA Impact	Practical Control	Control Limitation
1. Password Reuse & Weakness Same short password for email & portal.	Email Account & Student Portal	Confidentiality Integrity	Implement a strong, unique passphrase (>16 chars) managed via a trusted Password Manager.	Password managers can be a single point of failure if the master password is compromised.
2. Prompt Fatigue / Blind Approval Approving unexpected sign-in prompts.	Multi-Factor Auth (MFA) & Session	Confidentiality Integrity	Deploy Number Matching MFA push notifications instead of simple Yes/No approvals.	Users may still be trickable via targeted phishing or fatigue over high prompt volumes.
3. Postponing OS/Software Updates Delayed security patches on primary device.	Laptop Operating System & Data	Confidentiality Availability	Enable automated operating system and third-party software updates during off-hours.	Zero-day vulnerabilities remain unpatched until vendors publish official hotfixes.
4. Single Copy of Project File Only one project copy stored locally.	Academic Work & Project Files	Availability	Establish automated 3-2-1 backup strategy (Cloud Storage + External Drive).	Cloud sync tools can sync corrupted or encrypted ransomware files if active.
5. Shared Device Under Active Session Friend using laptop under Mira's login.	Active User Session & Personal Data	Confidentiality Integrity	Enforce automatic screen lock after 2 mins and create a separate 'Guest/Friend' OS account.	Does not prevent shoulder surfing or physical tampering if left unsupervised while unlocked.

Prioritised Remediation Strategy (Justification)

Priority Order: 1. Password Unique/Manager → 2. Number Matching MFA → 3. Automatic Backups.
Justification: Password reuse presents the largest attack surface as credential stuffing grants total access across multiple portals. Fixing authentication prevents unauthorized entry immediately. Enforcing number matching prevents push-fatigue exploitation. Securing project backups guarantees operational resilience against hardware failure or accidental deletion.

A3. Authentication vs. Authorisation (Portal Context)

> **Core Conceptual Distinction**
>
> **Authentication (Who you are):** The process of verifying identity. When Mira enters her username, password, and approves an MFA prompt, the portal authenticates her as the legitimate account owner.
>
> **Authorisation (What you can do):** The privilege engine enforcing access rights. Once authenticated, authorisation determines that Mira can view her own grades and submit her assignments, but restricts her from accessing other students' records or administrative settings.

Assignment 1

Himanshu Kumar

TASK B | ANALYSE A SUSPICIOUS MESSAGE (25 MARKS)

B1. Warning Sign Analysis

#	Quoted Phrase / Evidence	Security Scrutiny & Explanation
1	`awards@campus-awards.example`	**Sender Domain Mismatch:** The official college domain is stated as `campus.example`. The email originates from an unverified external subdomain structure designed to spoof official communications.
2	`Reply-To: help@personal-awards.example`	**Asymmetric Reply-To Header:** The reply path routes to a commercial generic domain rather than the institutional sender, routing student responses directly to an attacker-controlled inbox.
3	`FINAL WARNING - scholarship expires in 20 minutes`	**Urgency & Coercion Tactics:** Artificial time pressure induces panic, bypassing critical thinking and forcing immediate compliance before verification can occur.
4	`enter your college password and OTP`	**Credential Harvesting:** Legitimate institutional platforms never request static passwords alongside dynamic One-Time Passwords via external web links.
5	`Do not contact the college office... system unavailable`	**Isolation Mechanism:** Instructing the recipient to avoid out-of-band verification is a classic social engineering control designed to prevent out-of-band truth checking.

B2. Safe Verification Process

To safely verify this claim, the student must completely ignore all links and contact points in the email. Instead, navigate to the official, bookmarked institutional website (e.g., `https://campus.example`) by manually typing the URL into a browser, or call the published Financial Aid office number directly. **Why HTTPS & Display Names are insufficient:** HTTPS only guarantees an encrypted connection to the target server; it does not validate that the site owner is trustworthy (phishing sites routinely use free SSL certificates). Similarly, display names can be arbitrarily set by any sender.

B3. Incident Response Plan for Compromised Student

Immediate Containment: Immediately access the legitimate portal from a clean device and execute a password reset. Terminate all active web sessions across all registered devices. **Official Reporting:** Notify the institutional IT Security Helpdesk forwarding the malicious email headers and reporting potential compromised identity card images. **Follow-up Checks:** Inspect account settings for newly added forwarding rules, modified MFA methods, or unauthorized audit log actions. Contact bank/credit bureaus if sensitive ID documents were attached.

B4. Technical Attribution Limitations

> **Unestablished Fact:** It is impossible to determine the true identity or physical location of the sender from the message text alone, as headers and envelope data can be forged.
>
> **Required Evidence:** Raw RFC 822 email headers containing complete `Received:` hop paths, DKIM signatures, SPF validation results, and mail server IP addresses.

Assignment 1

Himanshu Kumar

TASK C | TRIAGE A SIGN-IN ALERT (25 MARKS)

C1. Chronological Timeline Analysis

The following timeline correlates synthetic log entries with the student statement to reconstruct authentication activity on 18 October 2026.

Time	Source IP	Observed Log Event	Analytical Interpretation
09:00 - 09:01	192.0.2.10 (Classroom)	Password: Success | MFA: Approved	Legitimate student sign-in from the regular classroom network egress. Fully authenticated session established.
10:14 - 10:16	198.51.100.23 (External)	Password: Failed (x2) → Password: Success	An external entity attempted credential brute-forcing/guessing. Correct password entered on 3rd attempt, indicating password exposure.
10:17	198.51.100.23 (External)	MFA: Denied	Attacker triggered MFA. Student explicitly denied the push prompt, recognizing an unauthorized request.
10:18 - 10:20	198.51.100.23 (External)	MFA: Approved → Session Created	Attacker re-sent MFA. Student approved prompt due to fatigue/confusion. Unauthorized session successfully created by attacker.

C2. Hypothesis Evaluation & Verification Checks

Primary Hypothesis (Adversary-in-the-Middle / Fatigue Attack): An external attacker obtained `student07`'s password (via phishing or leak) and repeatedly spammed MFA requests until the user approved out of confusion.

Alternative Hypothesis (Authorized User on VPN/Cellular): The student switched to a cellular hotspot, forgot their password twice, and misremembered their timeline.

> **Required Technical Verification Checks**
>
> **MFA Request Metadata:** Compare the precise device model, push token registration ID, and geolocation data for the 10:18 MFA event against student07's known registered mobile device. **User-Agent String Analysis:** Check browser headers and OS signatures logged at 10:20 against student07's baseline at 09:00 to detect environment shifts.

C3. Prioritised IT Response Actions

Session Revocation & Account Suspension (Priority 1): Immediately terminate all active OAuth refresh tokens/sessions for `student07` and temporarily freeze the account to block the active attacker. **Credential & MFA Reset (Priority 2):** Perform an administrative password reset and require re-registration of MFA methods under verified identity supervision. **Forensic Log Preservation (Priority 3):** Export and lock authentication logs, gateway firewall captures, and audit trails for `198.51.100.23` for incident documentation.

C4. Incident Summary Report

> **Executive Summary:** Account `student07` suffered an unauthorized session compromise at 10:20 IST from external IP `198.51.100.23` following multiple failed password attempts and MFA push fatigue. The student confirmed approving an unexpected prompt. Immediate priority is high: active session revoked, account locked, and credential reset mandated. Next action involves analyzing post-compromise session logs for data exfiltration.

Assignment 1

Himanshu Kumar

TASK D | REVIEW AN AI SECURITY ANSWER (25 MARKS)

D1. Correction of Unsafe AI Claims

Original Flawed Claim	Security Flaw Classification	Corrected Technical Explanation
"Email is safe because it uses HTTPS"	False Safety Assumption	HTTPS secures transit encryption but does not validate sender legitimacy. Phishing sites frequently utilize valid HTTPS certificates.
"IP 198.51.100.23 proves identity of thief"	Attribution Confabulation	IP addresses identify network endpoints, not human identities. The IP could be a proxy, VPN, TOR node, or compromised relay.
"MFA prevents every account compromise"	Overestimation of Security	MFA can be bypassed via MFA fatigue, AitM proxy kits (Evilginx), session hijacking, or SIM swapping (NIST SP 800-63B).
"Delete the suspicious logs"	Destructive Advice	Deleting logs destroys digital evidence required for incident response, legal compliance, and forensic analysis.
"Send student's password to support"	Credential Handling Violation	Cleartext passwords must never be transmitted or shared with anyone, including support staff. Access controls must be tested using non-production accounts.

D2. Structured AI Triage Prompt

> **Optimized Verification Prompt**
> *"Analyze the following synthetic log data for potential account compromise. Base your analysis strictly on the provided log events. Separate observed technical facts from analytical assumptions. Highlight explicit uncertainties. Do not request, generate, or process cleartext credentials or personal identifying information."*

D3. Corrected Security Advice

When investigating suspicious emails and log alerts, rely strictly on multi-factored technical evidence. HTTPS alone does not validate message origin. While MFA significantly reduces unauthorized access, it remains vulnerable to push fatigue and adversary-in-the-middle attacks. Preserve all system and authentication logs intact for forensic analysis. Never transmit passwords or live security tokens. If account compromise is suspected, immediately terminate active sessions, reset credentials through official channels, and contact institutional IT security via published out-of-band methods.

D4. AI-Use Declaration & Reference Notes

AI-Use Declaration: Generative AI was utilized solely as an investigative partner to assist in structuring technical explanations and refining draft formatting. All final claims, calculations, and analysis were manually reviewed and verified by the student.

> **References & Standards**
>
> **CISA Secure Our World Guidance:** Recognized standards for strong authentication and phishing prevention. (https://www.cisa.gov/secure-our-world) **NIST AI 600-1 (Generative AI Profile):** Guidelines addressing AI confabulation risk, hallucination management, and output verification requirements.